

一、填空题

1. 防火墙通常预定义了三类安全区域,受信区域 {Trust}、非军事化区域 {DMZ}和非受信区域 {Untrust},用户可以根据需要自行添加新的安全区域。
2. 防火墙的基本功能是{隔离}与{访问控制}。
3. 网络安全域是指同一系统内根据信息的{性质}、{使用主体}、{安全目标}和{策略}等元素的不同来划分的不同逻辑子网或网络。
4. 每一个逻辑区域内部有相同的{安全保护需求}、互相信任、具有相同的{安全访问控制}和{边界控制策略},且相同的网络安全域共享一样的安全策略。
5. 基于网络的检测与响应体系(NDR)通过对网络流量产生的数据进行{多手段检测}和{关联分析},主动感知传统防护手段无法发现的高级威胁。
6. 在下一代防火墙所采用的单路径处理架构中,数据包经过一次解码,一次性匹配{用户ID}、{应用ID}、{内容ID},最终将匹配结果同步至安全策略引擎。
7. 判断一个防火墙产品的性能主要依靠{网络吞吐量}、{并发连接数}、{新建连接速率}和{应用层性能指标}4个性能指标。
8. 防火墙技术有{包过滤技术}、{应用代理技术}、{会话机制}和{状态检测}、{应用识别技术}、{内容检查技术}等。
9. 包过滤防火墙通过检查每个报文的{源地址}、{目的地址}、{传输协议}、{端口号}、{ICMP的消息类型}等信息与预先配置的安全策略匹配情况,来决定是否允许该报文通过。
10. 过滤规则表是{静态}的,而会话表是{动态}的,会话表中记录了当前活动的合法连接,会随着数据包传输进行实时的更新。
11. 状态检测技术采用基于{连接}的状态检测机制。
12. 状态检测技术通过{规则表}与{会话表}间相互配合,对表中的各个连接状态因素加以识别。
13. 不同的安全域之间形成{域间关系},防火墙上大部分规则都在域间配置。
14. 报文从低级别的安全区域向高级别的安全区域流动时为{入/Inbound}方向;报文从由高级别的安全区域向低级别的安全区域流动时为{出/Outbound}方向。
15. IPv6 可聚合全球单播地址,用于全球范围的路由通信,前缀为{2000::/3}。
16. IPv6 链路本地地址,仅限同一物理链路使用,前缀为{FE80::/10}。
17. IPv6 唯一本地地址,类似IPv4私有地址,前缀为{FC00::/7}。
18. 策略路由用于区分将要做策略路由的流量,匹配条件包括:{报文源IP地址}、{目的IP地址}、{协议类型}、{应用类型}等。
19. 在一条策略路由规则中,各匹配条件之间是{与}的关系,报文必须同时满足所有匹配条件,才可以执行后续定义的转发动作。
20. 防火墙模式主要包括工作模式有:{路由模式}、{透明模式}、{混合模式}、{旁路模式}。
21. {NAT No-PAT}是一种 NAT转换时只转换地址,不转换端口,实现私网地址到公网地址一对一的地址转换方式。

22. {NAPT}是一种转换时同时转换地址和端口,实现多个私网地址共用一个或多个公网地址的地址转换方式。
23. {Smart NAT}是一种可以在 No-PAT的NAT模式下,指定某个IP地址预留做 NAPT方式的地址转换方式。
24. {Easy IP}是一种利用出接口的公网IP地址作为NAT转后的地址,同时转换地址和端口的地址转换方式。
25. DHCP服务器提供三种IP分配方式:{自动分配}、{动态分配}、{手动分配}。
26. DNS透明代理技术除了能够提高{多链路带宽利用率},更重要的是减少终端用户被{恶意修改DNS}带来的安全风险。
27. 代理 ARP 是ARP协议的一个变种,一般是使用在没有配置{默认网关}和{路由策略}的网络上。
28. 安全联盟(SA)是指 IPSec 中通信双方建立的连接。SA 由一个三元组来唯一标识,这个三元组包括:{安全参数索引(SPI)}、{目的IP地址}、{安全协议号}。
29. IPSec VPN 提供了三种安全机制:{认证}、{加密}和{数据完整性}。
30. QoS 提供以下三种服务模型:{Best-Effort Service}模型、{Integrated Service}模型、{综合服务}模型。
31. 实现区分服务的主要技术包括:{流分类}、{流量监管}、{流量整形}、{拥塞管理}、{拥塞避免}。
32. 常用的分组丢弃策略包括:{尾丢弃(Tail Drop)}、{RED (Random Early Detection)}、{WRED (Weighted Random Early Detection)}。
33. 根据分类规则的不同,流分类分为{简单流分类BA}和{复杂流分类 MF}。
34. 邮件过滤主要使用{IP地址检查}和{邮件内容过滤}技术。
35. AAA 指的是{认证}、{授权}、{计费}。
36. 802.1X协议是一种基于{接口}的网络接入控制协议。
37. MAC认证使用的用户名格式分为三种类型:{MAC地址格式}、{固定用户名形式}、{DHCP选项格式}。
38. PPPoE协议的工作流程包含{发现}和{会话}两个阶段。
39. 单包攻击的类型有:{畸形报文攻击}、{扫描类攻击}、{特殊控制报文攻击}。
40. 防火墙防御 DNS Flood 采用{TC源认证}方式。
41. 木马系统软件一般由{木马配置程序}、{控制程序}和{木马程序}三部分组成。

二、问答题

1. GB/T 20281—2015《信息安全技术 防火墙安全技术要求和测试评价方法》中对防火墙定义是什么?

答案: 部署于不同安全域之间,具备网络层访问控制及过滤功能,并具备应用层协议分析、控制及内容检测等功能,能够适用于IPv4、IPv6等不同的网络环境的安全网关产品。

2. 应用代理技术的原理是什么?有什么优缺点?

答案：应用代理技术的原理是:(1)应用层代理能实现比包过滤更加严格的安全策略。(2)基于代理的防火墙不会遇到传统数据包过滤防火墙的ACK攻击扫描问题。(3)应用层代理主要针对应用级,可梳理应用级协议。(4)应用层代理可以帮助优化性能。

优点:(1)支持可靠的用户认证。(2)过滤规则更易配置和测试。(3)可提供详细的日志和安全审计功能。(4)隐藏内部网络的IP地址。(5)解决合法IP地址不够用的问题。

缺点:(1)吞吐量要求较高时,代理防火墙会成为瓶颈。(2)存在兼容性问题,可伸缩性有限。

3. 试述 DPI技术和DFI技术的区别。

答案：(1)处理速度:DFI不需拆包,速度快;DPI需逐包拆包对比,速度慢。(2)维护成本:DFI成本较低;DPI需不断升级后台应用数据库,成本较高。(3)识别准确率:DPI可准确识别具体应用类型和协议;DFI仅能大致分类。且DPI无法识别加密流量,DFI不受影响。

4. 试述策略路由工作流程。

答案：(1)按照匹配顺序,先寻找第一条规则。(2)如果满足第一条匹配条件,则按指定动作处理。(3)如果不满足,则寻找下一条规则。(4)如果所有规则都不满足,报文按照路由表转发。策略路由优先级高于路由表。

5. 什么是流量监管?如何通过CAR限制某类报文流量?什么是令牌桶 TB?

答案：流量监管(TP)是监督进入网络的流量规格,丢弃超出规格的流量。使用承诺访问速率(CAR)来限制流量:先分类报文,再实施限流策略,符合规格的发送,超出的丢弃。CAR通过令牌桶(TB)实现,系统按设定速度向桶中放令牌,桶满则溢出;发送报文需消耗令牌,令牌不足则丢弃报文。

6. 什么是流量整形?流量整形如何使用缓冲区和令牌桶来完成?

答案：流量整形(TS)是限制流出流量的突发,使报文均匀发送。使用缓冲区和令牌桶完成:(1)无GTS队列时,若令牌充足则直接发送;若不足则进入GTS队列缓存。(2)有GTS队列时,新报文直接进入队列。(3)GTS按周期调度队列中的分组,每次发送均需消耗令牌。(4)若GTS队列已满,新报文被丢弃。